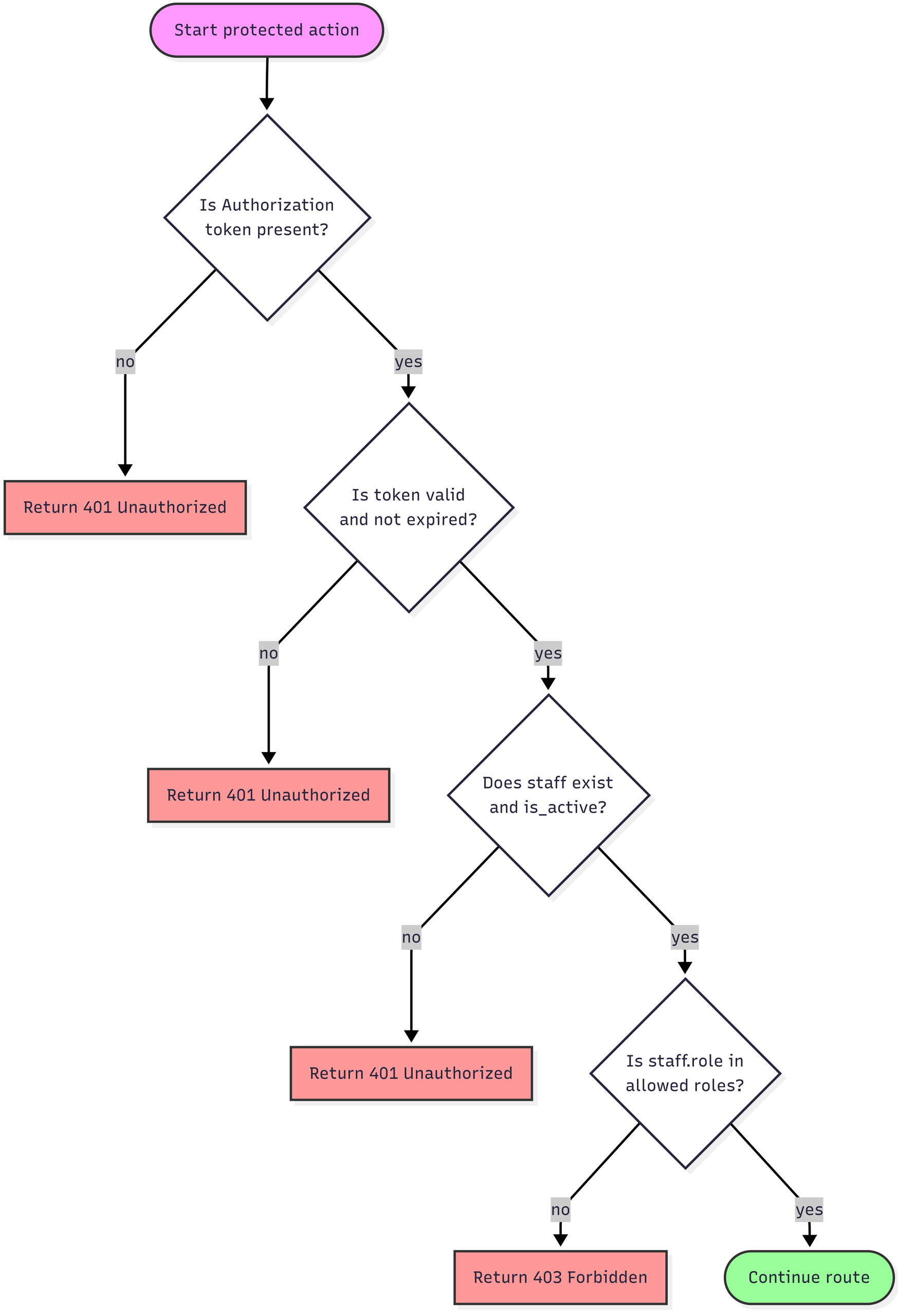

Start protected action
Is Authorization token present?
no
yes
Return 401 Unauthorized
Is token valid and not expired?
no
yes
Return 401 Unauthorized
Does staff exist and is_active?
no
yes
Return 401 Unauthorized
Is staff.role in allowed roles?
no
yes
Return 403 Forbidden
Continue route